

Overview

Part 12 —  AI Governance · 12-ai-governance/README.md

Module 12 — AI Governance

Where you are: Stop 12 of 16 on the end-to-end AI track. **Time:** ~14–18 hours · **Prereq:** Module 04 — LLM [04-llm] and Module 06 — AI Agents [06-ai-agents] (you need to know what these systems actually do before you can govern them).

Every other module in this track teaches you how to build an AI system. This one teaches you how an organization decides **whether it should, who is accountable when it's wrong, and how it proves that later** — to a regulator, an auditor, or its own board. AI governance is the internal operating model: committees, risk tiers, model risk management, oversight design, change control. It is not the same discipline as Module 14 — AI Compliance [14-ai-compliance] (the external laws you must satisfy) or Module 13 — AI Security [13-ai-security] (the technical controls that stop an attack). Governance is the layer that decides *what controls a given system needs* and *who signs off* — security and compliance are two of the things it points at.

Skip this module and you will still ship AI systems. You will just ship them the way most companies did in 2023–2024: a chatbot with no owner, a model version bump with no review, and an incident with no process — discovered by a subagent, prompt injection researcher, or news reporter before your own team noticed. Every large enterprise that has been burned by an AI incident traces it back to a missing answer to one of the questions this module asks: *who decided this was low-risk, and on what basis?*

Learning objectives

By the end of this module you can:

1. Explain the specific ways a probabilistic, emergent, third-party-dependent AI system breaks the assumptions built into traditional IT change and risk management — and why "it's just software" fails.
2. Apply the NIST AI RMF's four functions and describe what ISO/IEC 42001 requires of an AI management system, and choose which one (or both) fits a given organization.
3. Tier an AI use case by risk (data sensitivity, decision autonomy, affected-population size, reversibility of harm) and assign proportional controls instead of a one-size-fits-all review.
4. Design an AI governance operating model — committee, model risk management function, responsible AI office, named accountable executive — and say who does what, concretely, not as an org-chart fantasy.
5. Write a model card / system card that functions as a governance artifact, not documentation theater.
6. Choose the right human-oversight posture (in-the-loop, on-the-loop, in-command) for a given risk tier and design a gate that a human can meaningfully refuse, not rubber-stamp.

7. Run a change through governance — a prompt edit, a model version bump, a new vendor API — and describe what an incident response process and audit trail look like when it goes wrong anyway.

Suggested path

#	Do this	File	Time
1	Why AI governance, frameworks, risk tiering	notes/01-governance-fundamentals-and-frameworks.md	3h
2	Operating model, oversight, vendors, change & incident management	notes/02-operating-model-and-practice.md	3h
3	Build and run the risk register	code/ai_risk_register_template.py	2h
4	Read an annotated model card end to end	code/model_card_template.md	1h
5	Slides	slides/ (ai-governance.pptx)	1h
6	Exercises	lab/EXERCISES.md	5h
7	Papers & standards	papers/PAPERS.md	3h

The 16 terms you must own

AI risk tiering · NIST AI RMF (Govern/Map/Measure/Manage) · ISO/IEC 42001 · AI management system (AIMS) · model risk management (MRM) · AI governance committee · responsible AI office · accountable executive · model card · system card · human-in-the-loop · human-on-the-loop · human-in-command · third-party/vendor AI risk · AI change management · AI incident register

Exit check

You can take a real (or realistic) AI use case, run it through `code/ai_risk_register_template.py`, get a defensible risk tier out the other end, name the specific committee/role that must sign off at that tier, sketch the human-oversight posture it needs, and list the three pieces of evidence an auditor would ask you to produce a year later. If you can do that without opening this README again, you're done.

Where this module sits

This module (12)	Related module	What it covers instead
Internal policy, process, org design	14-ai-compliance	External law: EU AI Act, sector regulation, evidence for a specific statute
Internal policy, process, org design	13-ai-security	Technical controls: prompt injection defenses, red teaming, exfiltration prevention
Who decides, who signs off	15-ai-evals	How you actually measure whether a system is good enough to ship
Policy requirement for oversight	16-ai-tech-stack/tracks/langgraph	The technical mechanism (<code>interrupt()</code>) that implements an approval gate